

Experiment No: 5**Experiment Title:** FOSSA Software Composition Analysis (SCA) and SBOM**AIM**

To identify open-source dependencies, analyze vulnerabilities and licenses, and generate an SBOM using FOSSA.

REQUIREMENTS

- Kali Linux
- FOSSA account
- FOSSA API key
- FOSSA CLI
- Node.js/npm sample project
- Web browser

PROCEDURE

1. Install FOSSA CLI and verify with `fossa --version`.
2. Set `FOSSA_API_KEY`.
3. Prepare the sample project.
4. Run `fossa analyze`.
5. Review CVEs, severity, affected versions and remediation.
6. Review dependency licenses.
7. Generate SPDX using `fossa report attribution --format spdx` or `spdx-json`.

Term	Meaning
SCA	Software Composition Analysis: identifies open-source components in a project and checks them for known vulnerabilities and license issues.
SBOM	Software Bill of Materials: a list of the components in a piece of software.
SPDX	An SBOM format.
CycloneDX	An SBOM format.

8. Use FOSSA Reports > SBOM to generate CycloneDX JSON/XML where available.

COMMANDS / CONFIGURATION

```
fossa --version export
FOSSA_API_KEY="YOUR_API_KEY" fossa analyze
fossa report attribution --format spdx
fossa report attribution --format spdx-json
```

Missing from source: the FOSSA CLI install command and the sample project details (name, source). Enter what you used: [ENTER INSTALL COMMAND] / [ENTER SAMPLE PROJECT]. Never print your real API key in a screenshot.

KEY TERMS

FOSSA review items: dependencies, vulnerabilities, CVEs, severity, affected package versions, license information, remediation recommendations.

EXPECTED OUTPUT

FOSSA analyzed the dependencies; vulnerabilities/licenses were reviewed and SBOM output was generated. The figures below are Expected Output Illustrations generated to represent the expected result; they are not screenshots captured from an actual run.

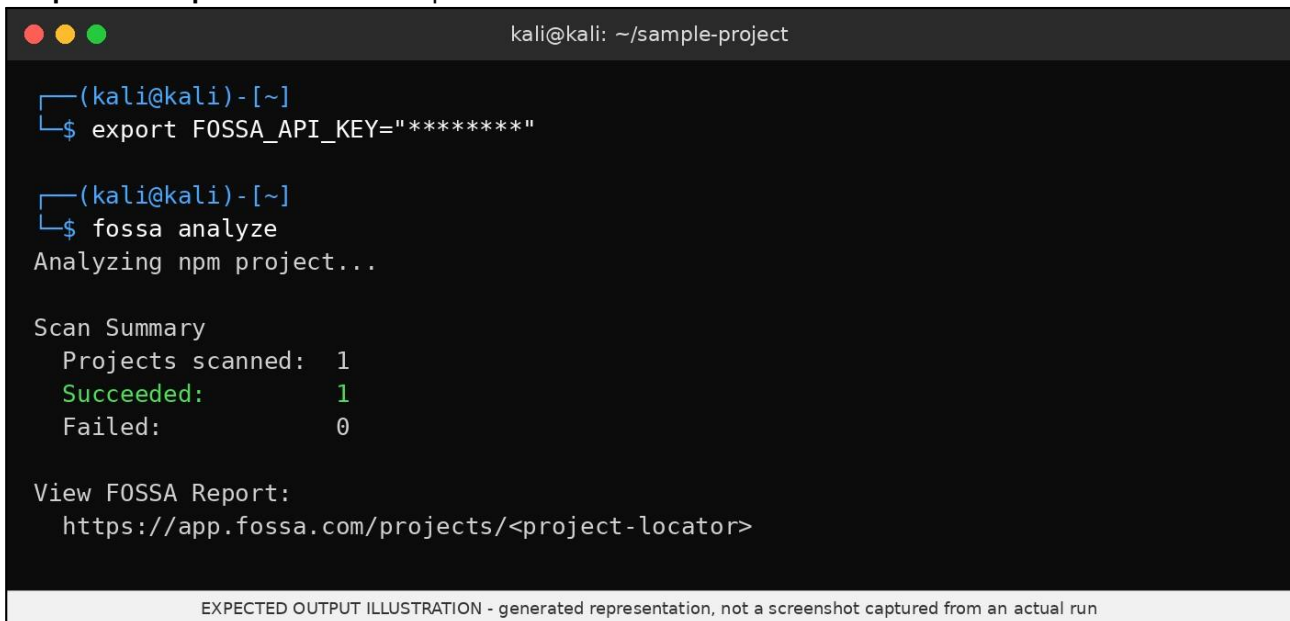


```
kali@kali: ~  
  
(kali@kali)-[~]  
└─$ fossa --version  
fossa-cli version 3.x.x
```

EXPECTED OUTPUT ILLUSTRATION - generated representation, not a screenshot captured from an actual run

Figure 1: FOSSA CLI Version

Expected Output: fossa --version prints the installed FOSSA CLI version.



```
kali@kali: ~/sample-project  
  
(kali@kali)-[~]  
└─$ export FOSSA_API_KEY="*****"  
  
(kali@kali)-[~]  
└─$ fossa analyze  
Analyzing npm project...  
  
Scan Summary  
  Projects scanned: 1  
  Succeeded: 1  
  Failed: 0  
  
View FOSSA Report:  
  https://app.fossa.com/projects/<project-locator>
```

EXPECTED OUTPUT ILLUSTRATION - generated representation, not a screenshot captured from an actual run

Figure 2: fossa analyze Scan Summary

Expected Output: API key set and fossa analyze scanning the npm project; summary shows 1 project scanned, 1 succeeded, 0 failed. The API key is masked.

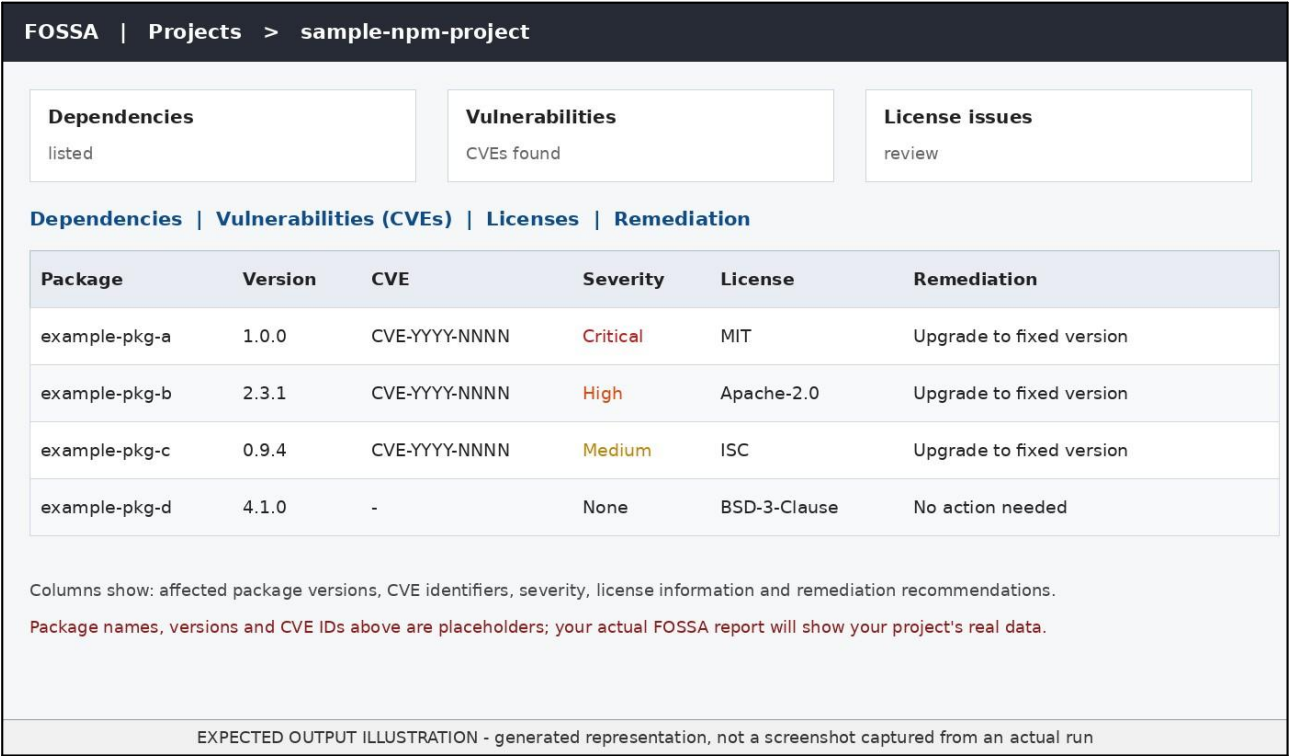


Figure 3: FOSSA Dashboard Report (Dependencies, Vulnerabilities, Licenses, Remediation)

Expected Output: Report layout showing dependencies with affected versions, CVEs, severity, licenses and remediation. Package names and CVE IDs are placeholders.

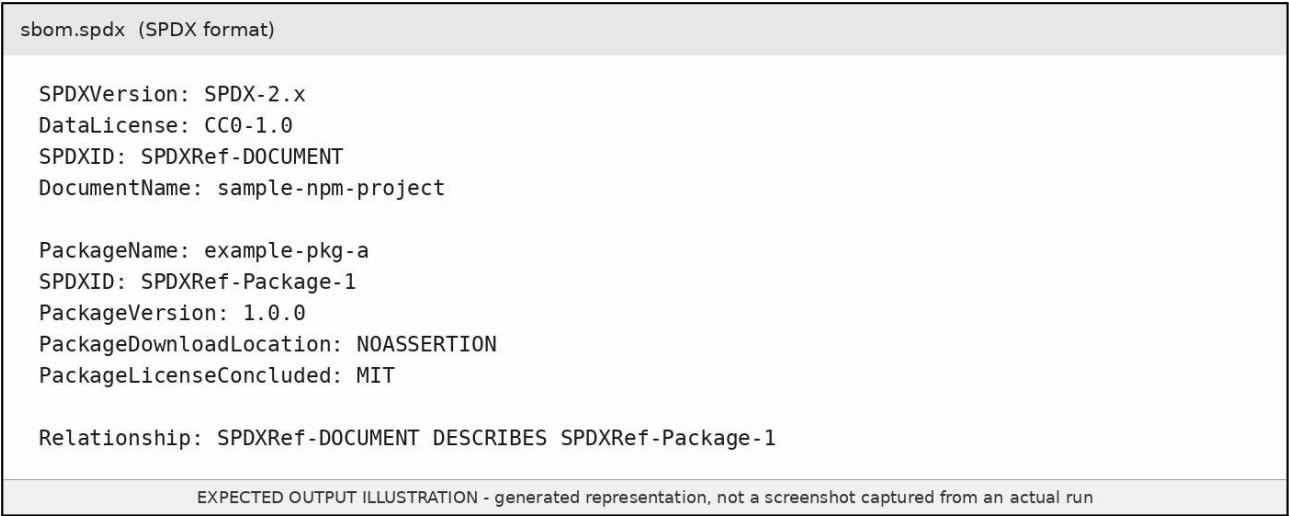


Figure 4: SPDX SBOM Output

Expected Output: SPDX document fields such as SPDXVersion, PackageName, PackageVersion, PackageLicenseConcluded and Relationship. Values are illustrative.

sbom.cdx.json (CycloneDX format)

```
{
  "bomFormat": "CycloneDX",
  "specVersion": "1.x",
  "components": [
    {
      "name": "example-pkg-a",
      "version": "1.0.0",
      "licenses": [ { "license": { "id": "MIT" } } ],
      "purl": "pkg:npm/example-pkg-a@1.0.0"
    }
  ],
  "dependencies": [ { "ref": "pkg:npm/example-pkg-a@1.0.0" } ]
}
```

EXPECTED OUTPUT ILLUSTRATION - generated representation, not a screenshot captured from an actual run

CONCLUSION

Software Composition Analysis was performed with FOSSA to review dependencies, vulnerabilities and licenses, and an SBOM was produced in SPDX (CLI) and CycloneDX (web UI where available) formats.